



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Rockwell Automation FactoryTalk Analytics PavilionX

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-16
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | Rockwell Automation FactoryTalk Analytics PavilionX - Vulnerability Report

Published: 2026-06-16 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

Rockwell Automation FactoryTalk Analytics PavilionX

1. Executive Summary

CISA and Rockwell Automation disclosed CVE-2025-14272, a high-severity missing-authorization vulnerability in Rockwell Automation FactoryTalk Analytics PavilionX. The affected product line is FactoryTalk Analytics PavilionX prior to version 7.01; Rockwell's vendor advisory identifies version 7.00 as affected and version 7.01 as corrected. The weakness is mapped to CWE-862 and concerns improper authorization enforcement in API endpoints that can permit an unauthorized actor to execute privileged operations.

The operational risk is concentrated in environments where PavilionX is reachable from broad enterprise, vendor-support, remote-access, or inadequately segmented OT-adjacent networks. PavilionX supports model predictive control and real-time analytics for industrial manufacturing processes, so privileged administrative access can affect user and role management, analytics administration, and the trust boundary around systems that influence quality, throughput, and production consistency. The advisory does not state that attackers can directly manipulate controllers through this flaw alone; the practical risk is abuse of PavilionX administrative functions as a stepping stone into industrial decision-support and optimization workflows.

Rockwell reports the issue was found internally during routine testing. CISA states that no known public exploitation specifically targeting this vulnerability had been reported as of the advisory release, and the CVSS vector reflects high attack complexity. Defenders should still treat exposed or weakly segmented PavilionX deployments as priority remediation targets because the vulnerability is network reachable, requires no prior privileges, and impacts administrative authorization.

Priority	Defensive Objective	Lost Boys Cyber Assessment
Immediate	Identify PavilionX deployments and confirm version 7.01 or later	Highest-value action; vulnerable 7.00 / pre-7.01 systems should be scheduled for controlled upgrade.
Immediate	Restrict PavilionX access paths to trusted administration networks and VPN/bastion flows	Reduces exploitability while patch windows are coordinated with operations.
Near term	Review PavilionX administrative user, role, and API activity for anomalous changes	Provides compensating visibility for environments with delayed upgrades.
Near term	Validate OT/IT segmentation and remote-access logging around PavilionX hosts	Limits post-exploitation movement from analytics administration into broader production support networks.

2. Intelligence Requirement

This report answers the following intelligence requirement for defense and manufacturing-sector stakeholders: what is CVE-2025-14272, which Rockwell Automation FactoryTalk Analytics PavilionX deployments are exposed, how could the vulnerability affect industrial operations, and what should defenders do next?

Requirement	Answer
Affected technology	Rockwell Automation FactoryTalk Analytics PavilionX, an analytics and model predictive control platform used to improve quality, throughput, and consistency in manufacturing processes.
Vulnerability	CVE-2025-14272, CWE-862 Missing Authorization in API endpoints.
Affected versions	CISA: FactoryTalk Analytics PavilionX earlier than 7.01. Rockwell: FactoryTalk Analytics PavilionX 7.00 affected, 7.01

	corrected.
Exploitation prerequisite	Network reachability to affected PavilionX API endpoints; no prior privileges or user interaction per CVSS vector.
Primary operational concern	Unauthorized execution of privileged operations, including user/role management and other administrative actions.
Exploitation status	CISA: no known public exploitation specifically targeting this vulnerability at initial release; Rockwell: Known Exploited Vulnerability status is No.
Defender decision	Upgrade to 7.01 or later, constrain access while coordinating patching, and hunt for suspicious administrative/API activity.

Assumptions and boundaries: Lost Boys Cyber did not obtain the vulnerable product, vendor patch diff, or exploit proof-of-concept for this assessment. Detection and hunting recommendations are therefore behavior- and telemetry-oriented rather than endpoint-specific signatures for exact URI paths. Organizations should tune the example analytics against PavilionX deployment topology, reverse proxy logs, authentication architecture, and local naming conventions.

3. Source Review and Confidence

Source	Key Contribution	Reliability / Confidence	Notes
CISA ICS Advisory ICSA-26-167-01	Public coordinator advisory, affected version range, CVSS 3.1/4.0 vectors, CISA recommended practices, exploitation-status statement.	High	CISA is authoritative for the ICS advisory republication and defensive guidance.
Rockwell Automation advisory SD1777	Vendor product description, affected software version, corrected version, affected catalog numbers, KEV status, and disclosure context.	High	Vendor advisory states the issue was found internally during routine testing.
CISA CSAF JSON for ICSA-26-167-01	Machine-readable advisory fields, references, product tree, CWE, remediation text, and score data.	High	Used to cross-check web advisory content and normalize facts.
FIRST CVSS vectors referenced by CSAF	Scoring details for CVSS:3.1 and CVSS:4.0.	Medium-High	Scoring is advisory-provided; no independent exploit validation was performed.

Confidence assessment: confidence is high that FactoryTalk Analytics PavilionX 7.00 / pre-7.01 deployments are affected by missing authorization in API endpoints and that upgrading to 7.01 or later is the vendor fix. Confidence is medium regarding exploit-path specifics because public advisories do not disclose endpoint names, request structures, or post-exploitation artifacts. Confidence is high that network segmentation, administrative-log review, and controlled patching are appropriate defensive actions for exposed PavilionX environments.

Evidence Item	Extracted Fact
CISA release date	2026-06-16
CISA alert code	ICSA-26-167-01
Rockwell advisory ID	SD1777

CVE	CVE-2025-14272
CWE	CWE-862 Missing Authorization
CVSS 3.1	7.0 High; CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:L
CVSS 4.0	8.3 High; CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:N/VC:H/VI:L/VA:L/SC:N /SI:N/SA:N
Affected product	FactoryTalk Analytics PavilionX
Corrected version	7.01 or later
Rockwell affected catalog numbers	9529-PV8DBENE; 95055-PV8BASET1T; 95055-PV8BASET1TPE

4. Key Findings

Finding	Severity	Confidence	Defensive Implication
CVE-2025-14272 allows unauthorized actors to execute privileged operations through improperly authorized API endpoints.	High	High	Treat PavilionX API exposure as an administrative-plane risk, not a generic web-app nuisance.
Exploitation is network-based and requires no prior account, but the advisory score marks attack complexity as high.	High	High	Do not rely on high complexity as a control; reduce reachable attack surface and monitor administrative actions.
User and role management are explicitly named impacted privileged operations.	High	High	Review administrative-account changes, role assignments, and any service-account modifications around PavilionX.
Vendor correction is available in FactoryTalk Analytics PavilionX 7.01.	High	High	Prioritize upgrade planning, especially for systems exposed to enterprise networks or vendor remote-access pathways.
CISA reports no known public exploitation at release.	Medium	High	No exploitation wave is confirmed, but preemptive remediation is justified because industrial analytics platforms are valuable footholds.

Detection must be environment-specific because public advisories do not disclose endpoint paths or request patterns.	Medium	Medium-High	Build telemetry around PavilionX host access, web/API logs, reverse proxy logs, authentication logs, and configuration-change records.
--	--------	-------------	--

5. Threat Context

FactoryTalk Analytics PavilionX is used in industrial manufacturing environments to support advanced process analytics, model predictive control, and real-time optimization. Platforms in this layer are attractive to attackers because they bridge process knowledge, production metrics, and administrator workflows even when they are not themselves controllers. A missing-authorization flaw in this context can create leverage over accounts, roles, and application administration at a point where engineering, operations, and business-continuity interests intersect.

No public reporting reviewed for this assessment links CVE-2025-14272 to active exploitation, ransomware intrusion sets, state-sponsored campaigns, or inclusion in CISA's Known Exploited Vulnerabilities catalog. The absence of known exploitation should not be read as absence of opportunity. OT-adjacent management systems are commonly reached after initial IT compromise through VPNs, remote monitoring tools, jump servers, flat enterprise-to-plant routes, or vendor-maintenance pathways.

Plausible abuse scenarios include unauthorized administrative change, post-compromise OT pivoting, vendor-access abuse, and analytics integrity pressure. MITRE ATT&CK mapping is conservative because the public advisory does not publish exploit tooling or observed intrusion procedures.

Framework	Technique	Name	Rationale
Enterprise ATT&CK	T1190	Exploit Public-Facing Application	Applies if PavilionX API endpoints are exposed to untrusted networks and exploited directly.
Enterprise ATT&CK	T1078	Valid Accounts	Unauthorized user/role management can enable or modify accounts that function as persistence or access mechanisms.
Enterprise ATT&CK	T1098	Account Manipulation	Explicitly relevant to user/role management abuse.
Enterprise ATT&CK	T1069	Permission Groups Discovery	Attackers abusing administrative APIs commonly enumerate roles/permissions before or after changes; include in hunt hypotheses if logs support it.
ICS ATT&CK	T0886	Remote Services	Relevant where access to PavilionX is mediated through VPN, jump hosts, or remote services into the industrial environment.
ICS ATT&CK	T0843	Program Download	Not directly evidenced for this CVE; include only as downstream risk if PavilionX administration connects into

			process-optimization deployment workflows in the local environment.
--	--	--	---

6. Detection and Hunting

Detection should focus on the PavilionX administrative plane, API behavior, identity changes, and network reachability. Because endpoint paths were not disclosed publicly, treat the examples below as detection engineering patterns. Replace hostnames, URI fragments, and user fields with local PavilionX telemetry.

Signal	Telemetry Source	Analytic Goal	Priority
API requests to PavilionX administrative/user/role endpoints from non-admin source networks	Reverse proxy, web server, WAF, firewall, EDR network telemetry	Detect unauthorized interaction with privileged API functions.	High
User or role creation/modification outside approved change windows	PavilionX app logs, IAM logs, SIEM change records	Identify potential account manipulation after exploitation.	High
Unauthenticated or failed-auth traffic followed by successful privileged API response	Web/API logs	Surface authorization bypass patterns where authentication state is absent or inconsistent.	High

```

title: Rockwell PavilionX Administrative API Access From Non-Admin Source
id: 46f4673a-27f0-4d65-bdb8-c517257fc572
status: experimental
description: Detects potential access to FactoryTalk Analytics PavilionX administrative API paths from sources that are not expected administration hosts. Tune URI fragments and source ranges to the local deployment.
references:
  - https://www.cisa.gov/news-events/ics-advisories/icsa-26-167-01
  - https://www.rockwellautomation.com/en-us/trust-center/security-advisories/advisory.SD1777.html
author: Lost Boys Cyber
date: 2026-06-16
tags:
  - attack.t1190
  - attack.t1098
  - cve.2025-14272
logsource:
  category: webserver
detection:
  selection_pavilionx_host:
    cs-host|contains:
      - 'pavilion'
      - 'pavilionx'
  selection_admin_api:
    cs-uri-stem|contains:
      - '/api/'
      - '/admin'
      - '/user'
      - '/users'
      - '/role'
      - '/roles'
  filter_expected_admin_sources:
    c-ip|cidr:
      - '10.10.10.0/24'
      - '10.20.5.0/24'
  condition: selection_pavilionx_host and selection_admin_api and not filter_expected_admin_sources
level: high
let Lookback = 30d;

```

```

let PavilionXHosts = dynamic(["pavilionx", "factorytalk-pavilion", "pavilion"]);
let ApprovedAdminNetworks = dynamic(["10.10.10.", "10.20.5."]);
DeviceNetworkEvents
| where Timestamp > ago(Lookback)
| where RemoteUrl has_any (PavilionXHosts) or DeviceName has_any (PavilionXHosts) or RemotePort in (80, 443, 8443)
| extend SourceIP = toString(LocalIP), Target = coalesce(RemoteUrl, RemoteIP)
| extend FromApprovedAdminPrefix = SourceIP startswith toString(ApprovedAdminNetworks[0]) or SourceIP startswith toString(ApprovedAdminNetworks[1])
| where FromApprovedAdminPrefix == false
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), ConnectionCount=count(), Devices=dcount(DeviceId), ExampleDevice=any(DeviceName) by SourceIP, Target, RemotePort, InitiatingProcessFileName, InitiatingProcessAccountName
| order by ConnectionCount desc

index IN (web,proxy,ot,firewall) earliest=-30d
(host="*pavilion*" OR url="*pavilion*" OR dest_host="*pavilion*")
(url="*/api/*" OR url="*/admin*" OR url="*/user*" OR url="*/role*" OR uri_path="*/api/*" OR uri_path="*/admin*" OR uri_path="*/user*" OR uri_path="*/role*")
(method=POST OR method=PUT OR method=PATCH OR method=DELETE OR http_method=POST OR http_method=PUT OR http_method=PATCH OR http_method=DELETE)
| eval src=coalesce(src_ip,clientip,src), user=coalesce(user,username,cs_username), path=coalesce(url,uri_path)
| stats count min(_time) as firstSeen max(_time) as lastSeen values(status) as status values(method) as method values(path) as paths by src user method dest_host
| convert ctime(firstSeen) ctime(lastSeen)
| sort - count

```

7. Recommendations

Priority	Owner	Action	Target Outcome
Critical	OT / Application Owner	Upgrade FactoryTalk Analytics PavilionX to version 7.01 or later after operational impact review.	Removes the known vulnerable condition.
Critical	Network / OT Security	Remove direct internet exposure and restrict PavilionX access to approved administration hosts, jump servers, and VPN paths.	Reduces unauthenticated network reachability to administrative APIs.
High	SOC / Detection Engineering	Deploy tuned web/API, EDR, VPN, and firewall analytics for PavilionX administrative access, user/role changes, and unusual source networks.	Provides visibility while patching and segmentation work complete.
High	Identity / OT Admins	Review PavilionX users, roles, service accounts, and recent administrative changes for unauthorized modification.	Detects potential account manipulation or misconfiguration.
High	Vulnerability Management	Add PavilionX version checks to recurring asset inventory and exception reporting.	Prevents untracked legacy 7.00 / pre-7.01 instances from persisting.
Medium	OT Engineering	Validate backups and configuration export procedures before upgrade.	Supports rollback and preserves production continuity during maintenance.

Medium	Third-Party Risk / Vendor Access	Confirm vendor remote-access paths use MFA, named accounts, session recording, and time-bound access windows.	Reduces abuse of trusted maintenance pathways.
--------	----------------------------------	---	--

8. References

- [1] CISA, "Rockwell Automation FactoryTalk Analytics PavilionX," ICSA-26-167-01, published 2026-06-16. <https://www.cisa.gov/news-events/ics-advisories/icsa-26-167-01>
- [2] CISA CSAF JSON for ICSA-26-167-01. https://raw.githubusercontent.com/cisagov/CSAF/develop/csaf_files/OT/white/2026/icsa-26-167-01.json
- [3] Rockwell Automation, "FactoryTalk® Analytics™ PavilionX™ - Improper API Authorization," advisory SD1777, published 2026-06-16. <https://www.rockwellautomation.com/en-us/trust-center/security-advisories/advisory.SD1777.html>
- [4] MITRE, CWE-862: Missing Authorization. <https://cwe.mitre.org/data/definitions/862.html>
- [5] CVE Program, CVE-2025-14272 record. <https://www.cve.org/CVERecord?id=CVE-2025-14272>